



Weekly IT Security Brief (Official-source-first) | 2026-04-26 06:01

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 8 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2025-29635(2026-05-08), CVE-2024-7399(2026-05-08), CVE-2024-57728(2026-05-08). Prioritize internet-facing and privileged systems first.
- Threat trend #1: AI-powered defense for an AI-accelerated threat landscape. AI-powered defense for an AI-accelerated threat landscape
- Threat trend #2: Detection strategies across cloud and identities against infiltrating IT workers. Detection strategies across cloud and identities against infiltrating IT workers
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2025-29635

CVE Title	CVE-2025-29635 dlink/dir-823x_firmware Unknown Type
CVE Description	A command injection vulnerability in D-Link DIR-823X 240126 and 240802 allows an authorized attacker to execute arbitrary commands on remote devices by sending a POST request to /goform/set_prohibiting via the corresponding function, triggering remote command execution.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	dlink/dir-823x_firmware, dlink/dir-823x
Risk Score	7.2 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-08
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2025-29635

CVE-2024-7399

CVE Title	CVE-2024-7399 samsung/magicinfo_9_server Unknown Type
CVE Description	Improper limitation of a pathname to a restricted directory vulnerability in Samsung MagicINFO 9 Server version before 21.1050 allows attackers to write arbitrary file as system authority.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	samsung/magicinfo_9_server
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-08
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2024-7399

CVE-2024-57728

CVE Title	CVE-2024-57728 simple-help/simplehelp Unknown Type
CVE Description	SimpleHelp remote support software v5.5.7 and before allows admin users to upload arbitrary files anywhere on the file system by uploading a crafted zip file (i.e. zip slip). This can be exploited to execute arbitrary code on the host in the context of the SimpleHelp server user.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	simple-help/simplehelp
Risk Score	7.2 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-08
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2024-57728

CVE-2024-57726

CVE Title	CVE-2024-57726 simple-help/simplehelp Unknown Type
CVE Description	SimpleHelp remote support software v5.5.7 and before has a vulnerability that allows low-privileges technicians to create API keys with excessive permissions. These API keys can be used to escalate privileges to the server admin role.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	simple-help/simplehelp
Risk Score	9.9 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-08
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2024-57726

CVE-2026-39987

CVE Title	CVE-2026-39987 coreweave/marimo Unknown Type
CVE Description	marimo is a reactive Python notebook. Prior to 0.23.0, Marimo has a Pre-Auth RCE vulnerability. The terminal WebSocket endpoint /terminal/ws lacks authentication validation, allowing an unauthenticated attacker to obtain a full PTY shell and execute arbitrary system commands. Unlike other WebSocket endpoints (e.g., /ws) that correctly call validate_auth() for authentication, the /terminal/ws endpoint only checks the...
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	coreweave/marimo
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-07
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-39987

CVE-2026-33825

CVE Title	CVE-2026-33825 microsoft/defender_antimalware_platform Unknown Type
CVE Description	Insufficient granularity of access control in Microsoft Defender allows an authorized attacker to elevate privileges locally.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/defender_antimalware_platform
Risk Score	7.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-06
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-33825

CVE-2026-20122

CVE Title	CVE-2026-20122 cisco/catalyst_sd-wan_manager Unknown Type
CVE Description	A vulnerability in the API of Cisco Catalyst SD-WAN Manager could allow an authenticated, remote attacker to overwrite arbitrary files on the local file system. To exploit this vulnerability, the attacker must have valid read-only credentials with API access on the affected system.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	cisco/catalyst_sd-wan_manager
Risk Score	5.4 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-23
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-20122

CVE-2026-20133

CVE Title	CVE-2026-20133 cisco/catalyst_sd-wan_manager Unknown Type
CVE Description	A vulnerability in Cisco Catalyst SD-WAN Software could allow an unauthenticated, remote attacker to view sensitive information on an affected system.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	cisco/catalyst_sd-wan_manager
Risk Score	6.5 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-04-23
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-20133

Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-6056

CVE Title	CVE-2026-6056 待核實 Unknown Type
CVE Description	Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
Affected Products	待核實
Risk Score	待核實 (待核實)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-6056

CVE-2026-0868

CVE Title	CVE-2026-0868 待核實 XSS
CVE Description	The EMC – Easily Embed Calendly Scheduling Features plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the plugin's calendly shortcode in all versions up to, and including, 4.4 due to insufficient input sanitization and output escaping on user supplied attributes. This makes it possible for authenticated attackers, with contributor-level access and above, to inject arbitrary web scripts in pa...
Affected Products	待核實
Risk Score	6.4 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-0868

CVE-2026-6559

CVE Title CVE-2026-6559 | 待核實 | XSS

CVE Description A weakness has been identified in Wavlink WL-WN579A3 220323. This affects the function sub_401F80 of the file /cgi-bin/login.cgi. This manipulation of the argument Hostname causes cross site scripting. Remote exploitation of the attack is possible. Upgrading the affected component is recommended. The vendor was contacted early, responded in a very professional manner and quickly released a fixed version of the affec...

Affected Products 待核實

Risk Score 4.3 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-6559>

CVE-2026-6560

CVE Title CVE-2026-6560 | 待核實 | Buffer Overflow

CVE Description A security vulnerability has been detected in H3C Magic B0 up to 100R002. This vulnerability affects the function Edit_BasicSSID of the file /goform/aspForm. Such manipulation of the argument param leads to buffer overflow. The attack can be executed remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

Affected Products 待核實

Risk Score 8.8 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-6560>

CVE-2026-6561

CVE Title CVE-2026-6561 | 待核實 | Unknown Type

CVE Description A vulnerability was detected in EyouCMS up to 1.7.1. This issue affects the function edit_adminlogo of the file application/admin/controller/Index.php. Performing a manipulation of the argument filename results in unrestricted upload. The attack is possible to be carried out remotely. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

Affected Products 待核實

Risk Score 4.7 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-6561>

CVE-2026-6562

CVE Title CVE-2026-6562 | 待核實 | SQL Injection

CVE Description A flaw has been found in dameng100 muucmf 1.9.5.20260309. Impacted is the function getListByPage of the file /index/Search/index.html. Executing a manipulation of the argument keyword can lead to sql injection. The attack may be performed from remote. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not respond in any way.

Affected Products 待核實

Risk Score 7.3 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-6562>



Report B: Threat Intelligence News (last 7 days)

Headline: AI-powered defense for an AI-accelerated threat landscape

Source	Microsoft Security Blog
Published	Wed, 22 Apr 2026 17:00:00 +0000
Key Takeaway	AI-powered defense for an AI-accelerated threat landscape
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/04/22/ai-powered-defense-for-an-ai-accelerated-threat-landscape/

Headline: Detection strategies across cloud and identities against infiltrating IT workers

Source	Microsoft Security Blog
Published	Tue, 21 Apr 2026 16:03:09 +0000
Key Takeaway	Detection strategies across cloud and identities against infiltrating IT workers
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	cloud/global
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/04/21/detection-strategies-cloud-identities-against-infiltrating-it-workers/

Headline: CISA Warns of FIRESTARTER Malware Targeting Cisco ASA including Firepower and Secure Firewall Products

Source	CISA News
Published	Thu, 23 Apr 26 12:00:00 +0000
Key Takeaway	CISA Warns of FIRESTARTER Malware Targeting Cisco ASA including Firepower and Secure Firewall Products
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-warns-firestarter-malware-targeting-cisco-asa-including-firepower-and-secure-firewall-products

Headline: CISA, National Cyber Security Centre (NCSC) UK, and Global Partners Issue Advisory on Chinese Government-Linked Covert Cyber Networks

Source	CISA News
Published	Thu, 23 Apr 26 12:00:00 +0000
Key Takeaway	CISA, National Cyber Security Centre (NCSC) UK, and Global Partners Issue Advisory on Chinese Government-Linked Covert Cyber Networks
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	government/uk
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-national-cyber-security-centre-ncsc-uk-and-global-partners-issue-advisory-chinese-government

Headline: Snow Flurries: How UNC6692 Employed Social Engineering to Deploy a Custom Malware Suite

Source	Mandiant Blog
Published	Thu, 23 Apr 2026 14:00:00 +0000
Key Takeaway	Following this, the attacker sent a phishing message via Microsoft Teams, posing as helpdesk personnel offering assistance with the email volume. Finally, EDR telemetry logged the threat actor performing screen captures on the Domain Controllers, specifically targeting in-focus instances of Microsof Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/待核實
Technique	T1003.001,T1003.002,T1003.003
MITRE ATT&CK	T1003.001, T1003.002, T1003.003, T1005, T1007, T1012, T1016, T1018, T1020, T1021.001, T1021.002, T1027, T1027.010, T1027.015, T1033, T1036.005, T1046, T1053, T1053.005, T1055, T1057, T1059, T1059.001, T1059.003, T1059.006, T1059.007, T1059.010, T1068, T1070.004, T1071.001, T1074, T1082, T1083, T1087.001, T1090, T1105, T1110.001, T1110.003, T1112, T1113, T1134, T1134.001, T1140, T1176.001, T1202, T1204.001, T1204.002, T1489, T1518, T1543, T1543.003, T1547.001, T1547.009, T1552.001, T1559, T1560, T1560.001, T1562.001, T1564.001, T1566.002, T1567, T1567.002, T1569.002, T1572, T1608.002, T1608.005, T1622
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/unc6692-social-engineering-custom-malware/

Headline: Defending Your Enterprise When AI Models Can Find Vulnerabilities Faster Than Ever

Source	Mandiant Blog
Published	Thu, 16 Apr 2026 14:00:00 +0000
Key Takeaway	Introduction Advances in AI model-powered exploitation have demonstrated that general-purpose AI models can excel at vulnerability discovery, even without being purpose-built for the task. Eventually, capabilities such as these will be integrated directly into the development cycle, and code will be Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/global
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/defending-enterprise-ai-vulnerabilities/

Headline: It pays to be a forever student

Source	Cisco Talos Blog
Published	Thu, 23 Apr 2026 18:00:22 GMT
Key Takeaway	It pays to be a forever student Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerability Research BACK Vulnerability Reports Microsoft Advisories Incident Response Incident Response BACK Reactive Services Proactive Services Emerge Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/it-pays-to-be-a-forever-student/

Headline: UAT-4356's Targeting of Cisco Firepower Devices

Source	Cisco Talos Blog
Published	Thu, 23 Apr 2026 15:10:57 GMT
Key Takeaway	UAT-4356 exploited n-day vulnerabilities (CVE-2025-20333 and CVE-2025-20362) to gain unauthorized access to vulnerable devices. UAT-4356's Targeting of Cisco Firepower Devices Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerabili Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/la...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	CVE-2025-20333, CVE-2025-20362
Link	https://blog.talosintelligence.com/uat-4356-firestarter/

Headline: Researchers Uncover Pre-Stuxnet ‘fast16’ Malware Targeting Engineering Software

Source	The Hacker News
Published	Sat, 25 Apr 2026 14:56:00 +0530
Key Takeaway	Cybersecurity researchers have discovered a new Lua-based malware created years before the notorious Stuxnet worm that aimed to sabotage Iran's nuclear program by destroying uranium enrichment centrifuges. According to a new report published by SentinelOne, the previously undocumented cyber sabotage Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/laterna...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/04/researchers-uncover-pre-stuxnet-fast16.html

Headline: CISA Adds 4 Exploited Flaws to KEV, Sets May 2026 Federal Deadline

Source	The Hacker News
Published	Sat, 25 Apr 2026 10:38:00 +0530
Key Takeaway	Cybersecurity and Infrastructure Security Agency (CISA) on Friday added four vulnerabilities impacting SimpleHelp, Samsung MagicINFO 9 Server, and D-Link DIR-823X series routers to its Known Exploited Vulnerabilities (KEV) catalog, citing evidence of active exploitation. The list of vulnerabilities Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral move...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	CVE-2024-57726
Link	https://thehackernews.com/2026/04/cisa-adds-4-exploited-flaws-to-kev-sets.html

Headline: China-Linked APT GopherWhisper Abuses Legitimate Services in Government Attacks

Source	SecurityWeek
Published	Sat, 25 Apr 2026 10:50:00 +0000
Key Takeaway	The post China-Linked APT GopherWhisper Abuses Legitimate Services in Government Attacks appeared first on SecurityWeek . China-Linked APT GopherWhisper Abuses Legitimate Services in Government Attacks - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webcasts Virtual Events ICS: ICS Cybersecu Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	government/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/china-linked-apt-gopherwhisper-abuses-legitimate-services-in-government-attacks/

Headline: Pre-Stuxnet Sabotage Malware 'Fast16' Linked to US-Iran Cyber Tensions

Source SecurityWeek

Published Fri, 24 Apr 2026 14:57:18 +0000

Key Takeaway Pre-Stuxnet Sabotage Malware 'Fast16' Linked to US-Iran Cyber Tensions - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webcasts Virtual Events ICS: ICS Cybersecurity Conference Malware & Threats Cyberwarfare Cybercrime Data Breaches Fraud & Identity Theft Nation-State Ransomware Vulnerabilit Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous...

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target ot/待核實

Technique Malware Deployment

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.securityweek.com/pre-stuxnet-sabotage-malware-fast16-linked-to-us-iran-cyber-tensions/>

Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

[**https://attack.mitre.org/**](https://attack.mitre.org/)

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)